

한 국 관 광 공 사 감 사

통보 · 권고

감 사 명 : 2019년 정보기술(IT) 분야 특정감사

제 목 : 정보시스템 권한 회수 및 관리 업무 불철저

관계부서 : □□팀, ■■팀, △△팀, ▲▲팀, ◇◇팀

내 용

1. 업무개요

“정보시스템”이란 정보통신기술을 이용하여 정보의 수집, 축적, 전달, 가공, 출력 등을 처리하는 시스템으로서 하드웨어, 소프트웨어 및 통신망 등을 포괄하여 말하며⁴⁶⁾, 공사의 주요 정보시스템으로는 대내 서비스를 위한 기업포털시스템(이하 “KTO-Net”이라 한다), 전략경영시스템(이하 “SMS⁴⁷⁾”라 한다), 관광마케팅시스템(이하 “TMS⁴⁸⁾”라 한다), 대외 서비스를 위한 대외관광정보시스템(VisitKorea.or.kr) 등이 있다.

KTO-Net은 대내 공지사항, 인사발령, 사규 등 각종 정보와 자료가 공유되고 전자결재가 이루어지는 등 임직원의 업무처리에 가장 기본이 되는 시스템이다.

SMS는 경영계획, 회계, 인사관리 등 각종 경영관리 업무를 위한 공사 내부 시스템으로 시스템 특성상 ◇◇팀은 시스템 관리자로서 전체 권한관리를 관장하는 역할을 수행하고, 단위 시스템별 권한관리는 각 부서에 위임·운영하고 있다. 이에 따라 각 주관부서 담당자가 일반사용자에게 SMS 단위 시스템 내 메뉴별 접근 권한을 부여하는 역할을 수행하고 있다.

46) 「정보화 업무규정」 제3조

47) Strategic Management System

48) Tourism Marketing System

2. 관계법령 및 판단기준

「정보보안업무운영요령(이하 “운영요령”이라 한다)」 제38조 제1항에 따르면, 정보화기술부서는 정보시스템의 계정 및 권한 관리 시, 사용자의 업무분장 및 직무기술에 따른 최소한의 접근권한 부여, 관리자계정은 일반 사용자에게 부여하지 않고 별도 기록 관리, 직원의 퇴직 또는 보직변경 발생 시 접근권한 조정 등의 사항을 고려하여야 한다. 그리고 정보화기술부서는 운영요령 같은 조 제3항에 따라 장기미접속 계정의 사용을 중지하며, 계정 및 권한부여의 적정성에 대한 주기적인 검토 및 재정의 작업을 실시하도록 되어있다.

그리고 운영요령 제41조 제1항에서는 정보화기술부서 및 정보화사업부서는 정보시스템의 효율적인 통제·관리, 사고발생시 추적 등을 위하여 사용자의 정보시스템 접근기록을 유지 관리하여야 하고, 같은 조 제5항에 따르면 정보시스템별 운용관리자⁴⁹⁾는 접근기록을 확인하며 이상 유무를 점검하여야 한다고 규정하고 있다.

따라서 정보화기술부서인 ◇◇팀은 정보시스템별 비인가 사용자의 접근이나 접근 사용자의 불특정한 이상 활동 발생 여부에 대해 정기적으로 점검하고 보고하는 절차를 운영하는 것이 바람직하다. 다만, 사용자 조직별 부여된 권한에 따라 접근할 수 있는 메뉴가 구분된 SMS의 경우, ◇◇팀에서는 각 시스템별 조직에게 할당된 권한의 적정성에 대하여 점검하고, 정보화사업부서인 SMS 시스템별 주관 부서에서는 SMS 주요 메뉴에 대한 비인가 사용자 또는 접근 가능자의 활동 기록

49) 「정보보안업무운영요령」 제37조 제1항에 따라 정보화기술부서는 정보시스템의 효율적인 보안관리를 위하여 정보시스템별로 운용관리자를 지정·운용하여야 하며, ◇◇팀에서는 구성원 업무분장에 따라 경영지원 시스템 운용관리자(현재 차장 A)와 마케팅시스템 운용관리자(현재 차장 B)를 운용하고 있음

에 대하여 주기적으로 검토하고 그 결과를 문서화하여 책임자에게 보고하는 절차가 필요하다고 판단된다.

또한, SMS는 공사 경영관리와 관련한 주요 정보가 취급되는 시스템이고 사용자의 소속 조직 또는 담당 업무에 따라 차등 부여된 권한에 따라 접근할 수 있는 메뉴가 구분되어 있으므로 SMS 시스템별 주관부서는 적절한 검토와 승인 절차를 거쳐 일반사용자에게 메뉴 사용 권한을 부여하여야 하고, 이러한 권한 부여 내역을 기록·관리할 필요가 있다.

3. 감사결과 확인된 문제

공사의 주요 대내외 서비스를 위한 정보시스템인 기업포탈시스템(KTO-Net), 전략경영시스템(SMS), 마케팅시스템(TMS), 대외관광정보시스템(Visitkorea.or.kr), 모바일오피스시스템의 5개 시스템을 대상으로 계정 및 권한관리, 접근통제, 로그인 및 비밀번호관리, 프로그램 변경 등 정보시스템 운영보안과 관련한 내부 통제 적정성을 점검한 결과, 운영체제(OS; Operation System), 데이터베이스(DB), 네트워크 측면에서는 미흡 사항이 발견되지 않았으나, 응용시스템(application)과 관련하여 다음과 같은 문제점이 발견되었다.

가. 정보시스템 권한 회수의 적시성 관련

공사의 각종 내부 정보시스템은 인사시스템과 연계되어 통합인증(SSO; Single Sign On⁵⁰⁾)을 통한 시스템 접근이 가능하며, 직원의 입사 시 △△팀에서 사용자계정(ID)을 접수받아 일괄 등록하면 통합인증을 위한 계정이 최초로 생성되고, 사용자별로

50) 단 한 번의 로그인만으로 기업의 각종 시스템이나 인터넷 서비스에 접속하게 해주는 보안 응용 솔루션으로 각각의 시스템마다 인증 절차를 밟지 않고도 1개의 계정만으로 다양한 시스템에 접근할 수 있어 ID, 비밀번호에 대한 보안 위험 예방과 사용자 편의 증진, 인증 관리비용의 절감 효과가 있음
※ 출처: 한국정보통신기술협회 정보통신용어사전(<https://terms.tta.or.kr>)

접근할 수 있는 시스템 권한은 구분하여 부여하고 있다. 그리고 계정의 변경 및 회수 또한 인사발령 사항에 따라 인사시스템의 데이터베이스가 변경되면 로직(logic)에 따라 자동으로 처리되도록 통제하고 있다.

그러나 최초에 △△팀 담당자가 사용자별 인사 변동사항을 인사시스템에 입력하는 것을 수동으로 처리하고 있기 때문에 퇴직자의 인사발령 정보 입력이 불가피하게 퇴사일에 이루어지기 어려운 경우 계정의 회수가 적시에 이루어지지 못할 위험이 있다. 이에 최근 1년(2018.6.1.~2019.5.31.) 동안의 퇴직자 계정 회수 현황을 점검한 결과, 회수가 적시(퇴직 당일 또는 익일⁵¹⁾)에 이루어진 경우는 17명⁵²⁾의 퇴직자 중 2명에 불과한 것으로 나타났다. 권한 회수가 지연된 사례의 대부분은 퇴직일 또는 그 다음날이 주말, 휴일 등 근무일이 아닌 사유로 1~2일 지연된 경우였으며, 이 외에 6일 지연된 사례가 1건 있었다.

나. 정보시스템 권한 관리 관련

KTO-Net은 공사 내부망 접근에 따른 임직원의 업무처리 시 기본적으로 접속이 요구되는 시스템이며 사용자가 속한 조직에 따라 접근할 수 있는 메뉴가 구분되도록 접근을 통제하고 있다. 이러한 조직별 접근 가능 메뉴는 ◇◇팀에 의해 롤 매트릭스(Role Matrix)로 시스템에 반영되어 있으나, 조직별로 접근할 수 있는 롤 매트릭스에 대해 주기적으로 검토하는 통제는 존재하지 않으며, 관련 기록 또한 문서화하지 않고 있었다.

51) 「취업규칙」 제52조의2에 따르면 인사명령지상의 퇴직일은 근무를 한 것으로 보므로 퇴직일 다음날 권한 회수가 이루어진 경우까지 적시 회수로 판단함

52) 해당 기간 중 퇴직자는 총 18명이나, 1명(C)의 정확한 퇴직 등록일이 프로그램 오류로 확인 불가하여 제외함

SMS의 단위 시스템별로 권한 관리자 역할을 위임받은 각 주관부서 담당자 현황을 살펴본 결과, 시스템 관리자(운영PM)가 각 주관부서 담당자를 지정하였으나 이와 관련한 검토 및 승인 기록은 존재하지 않았다. 또한, 각 주관부서 담당자(권한 관리자)가 담당 메뉴별 접근 권한을 부여/변경/회수하는 권한을 가지고 있어 일반 사용자에게 기본 권한⁵³⁾ 외에 업무상 필요한 권한을 부여하는 역할을 맡고 있는데, 이러한 역할 수행 시 내부적인 검토·승인 절차 없이 담당자가 자체적으로 판단하여 처리하고 있다. 그리고 이 과정에서 문서를 통해 권한 요청을 하는 일부 경우⁵⁴⁾를 제외한 대부분의 일반사용자 권한 부여 요청이 전화 통화 또는 사내 메신저를 통하여 이루어지고 있어 권한 부여/변경/회수에 대한 검토 및 승인 내역이 기록·관리되지 않고 있다.

그리고 SMS 단위 시스템별 권한 부여자의 역할, 세부 프로그램별 권한지정 대상 팀 또는 업무에 대한 정의 등에 대한 문서화나 관련 업무매뉴얼, 관리지침도 마련되어 있지 않아 SMS 주관부서 담당자별로 본인이 부여받은 권한과 관련한 역할과 책임에 대하여 이해하고 있는 정도가 상이하였다.

다. 정보시스템 권한 보유 및 계정 접근의 적정성 점검활동 관련

KTO-Net의 경우, 사용자의 접속 기록이 통합인증 솔루션을 통해 로그(Log)로 기록되고 있으나, KTO-Net과 통합인증 솔루션의 운영을 주관하는 ◇◇팀에서 시스템에 접근하는 사용자를 주기적으로 검토하는 통제(Access Review)는 존재하지 않으며, 관련 기록 또한 문서화가 수행되지 않고 있다.

53) 정규직 입사 시 SMS의 가장 기본적인 메뉴 접근권한을 부여하며, 부서이동 및 퇴직 시에는 기존 보유하고 있는 접근권한이 자동 회수되어 신규 입사자와 같은 기본 메뉴 접근권한으로 초기화됨

54) 해외지사 현지직원 권한 부여의 경우 전자결재 간이서식 양식을 활용한 대내 협조문을, SMS 재무회계 시스템의 특정 기간동안 접근을 요청하는 경우 대내 협조공문을 수령하여 권한을 부여하고 있어 신청 기록은 남고 있지만, 이 경우에도 별도 검토나 승인 절차는 없으며 승인내역이 기록·관리되고 있지는 않음

SMS의 경우에도 마찬가지로 운영을 주관·관리하는 ◇◇팀과 메뉴별 주관부서인 □□팀, ■■팀, △△팀, ▲▲팀은 시스템에 접근하는 사용자를 주기적으로 검토하는 통제 활동을 하고 있지 않았으며, 따라서 관련 기록 또한 문서화되지 않고 있었다. 더불어 시스템 데이터베이스 상에도 권한이 부여/변경/회수된 일시는 기록되고 있지 않고 있어 현재 권한 보유자의 권한부여일만 파악이 가능하고 과거 권한을 보유하고 있었던 사람에 대한 내역은 파악할 수 없었다.

관계부서 의견 및 검토결과

◇◇팀은 대부분의 감사결과를 수용하면서 더욱 효율적인 통제, 관리시스템의 구축을 추진하겠다고 답변하였다. 다만, 정보시스템의 비인가된 사용자나 접근가능자의 활동기록을 주기적으로 검토하고 내부 보고할 필요성이 있다는 지적에 대해서는 현재 내부 시스템은 인가자만 접근할 수 있고 비인가자는 접속이 불가능하도록 되어있기 때문에 활동기록 검토 절차는 불필요하다는 의견을 제시하였다. 그러나 시스템 오류나 우회 접속, 계정 도용 등 발생가능한 위험을 완전히 배제할 수는 없기 때문에 업무 효율성을 고려하되 「정보보안업무 운영요령」에 규정된 최소한의 점검 활동은 수행할 필요가 있다고 판단된다.

△△팀은 정보시스템 권한 회수의 적시성과 관련한 감사결과를 수용하면서 퇴직 처리 및 일부 전보 발령을 예약하여 자동으로 처리할 수 있는 시스템을 개발하겠다는 의견을 제시하였다.

SMS 각 단위 시스템의 주관부서인 □□팀, ■■팀, △△팀, ▲▲팀은 대부분의 감사결과를 수용하면서 권한 부여 및 관리 업무를 철저히 하겠다는 의견을 제시

하였다. 다만, △△팀의 경우 일반사용자는 어떤 메뉴 권한을 신청해야하는지 알 수 없고 인사관리 시스템 권한관리자가 인사발령에 따라 직원별 담당 업무에 맞게 해당 프로그램 권한을 부여하고 있으며, ▲▲팀의 경우 결산업무 담당자가 재무회계 시스템 권한관리자를 맡도록 되어 있기 때문에 별도의 검토 및 승인 절차는 불필요하고 역할 정의 매뉴얼을 마련하여 이에 따라 권한을 부여하고 그 내역을 기록하여 관리하는 것이 효율적이라는 의견을 제시하였다.

조치할 사항

한국관광공사 사장은

① 직원의 인사사항 변동 시 정보시스템 권한이 적시에 회수될 수 있도록 하는 방안을 마련하시고,**(통보)**

② 정보시스템의 계정 및 권한부여 적정성에 대해 주기적으로 검토 및 재정의 하고, 정보시스템 접근기록을 확인하여 이상 유무를 점검하며, SMS 시스템별 권한관리자의 역할을 명확히 하고 권한부여 이력을 관리하는 내부통제 절차를 수립·운용하시기 바랍니다.**(권고)**